

GRC102: INFORMATION SECURITY GOVERNANCE

Week 1 Practical Laboratory

Name: Adebukola Olanipekun

REG NO.: C11/26/CGRCE/17603

Cohort / Batch : 11

Email address bukolufemi@gmail.com

Date Submitted : 10/9/2026

Information Security Governance in Action

GlobalHealth Connect (GHC) - Executive Governance Simulation

Task 1: Governance Blueprint

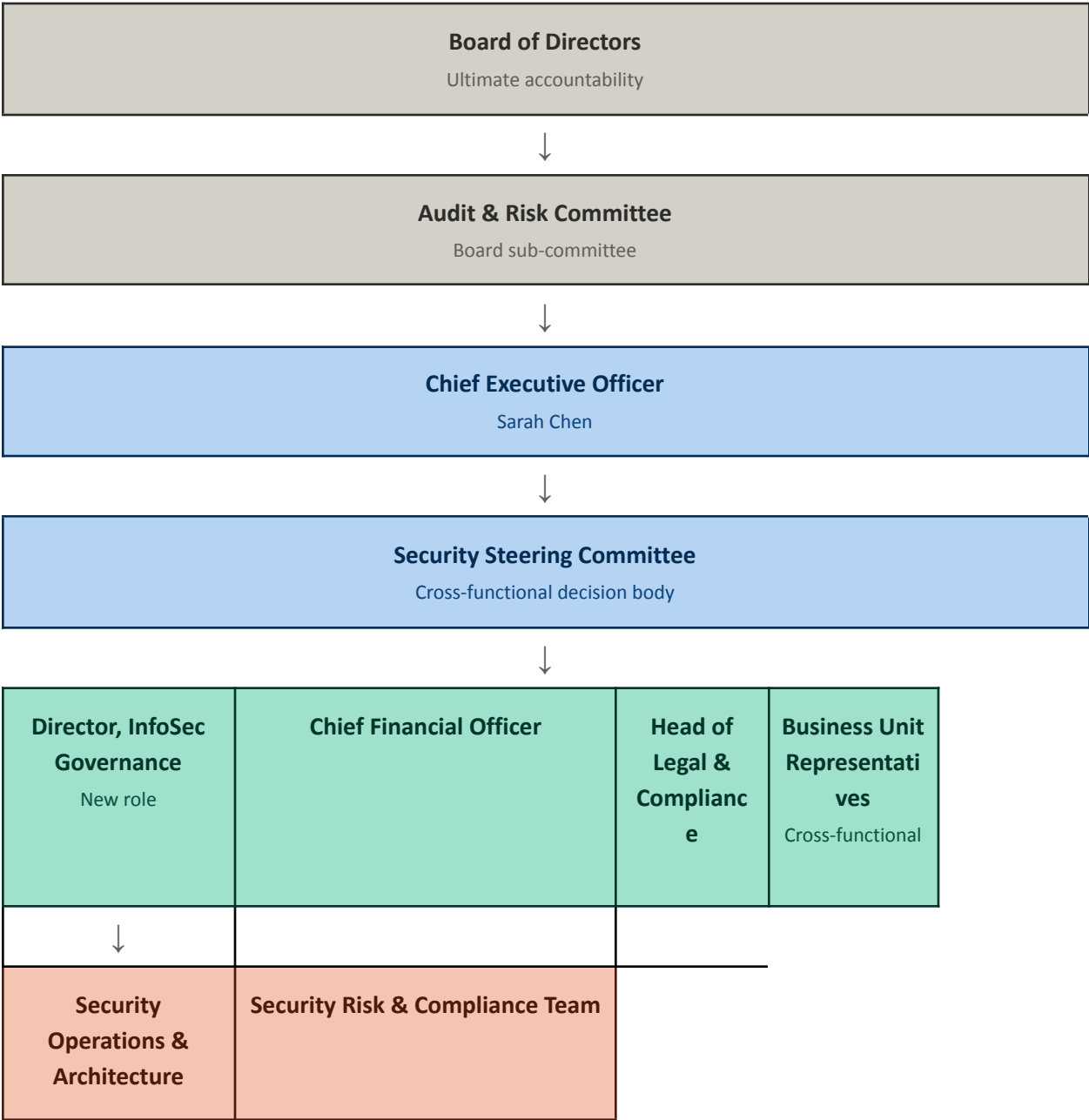
1.1 Current-State Governance Gap Assessment

GlobalHealth Connect's current ad-hoc security approach exhibits five critical governance weaknesses that must be addressed immediately following the recent data-leakage near-miss.

Weakness	Evidence	Governance Issue	Business Impact
Diffuse Accountability	Security activities performed by IT Manager John Smith without formal mandate	No clear ownership of security decisions; IT performs security as secondary duty	Decisions lack authority; no individual or body is accountable for security outcomes
No Strategic Direction	Policies inherited from acquisitions, inconsistent and outdated	Security operates without strategic alignment to GHC's growth and innovation goals	Security investments not linked to business value; reactive rather than proactive approach
Absent Board Oversight	Board receives no structured security reporting	Governance gap between operations and Board-level accountability	Board cannot exercise fiduciary responsibility for cyber risk

Weakness	Evidence	Governance Issue	Business Impact
Reactive Risk Management	"Audit-driven rather than continuously monitored" compliance approach	No proactive risk assessment or treatment process	Vulnerabilities persist until audit finds them; near-miss incidents not investigated for root causes
Insufficient Cross-Functional Input	Dispute between CTO and IT Manager over password policy indicates no formal resolution mechanism	Security decisions made in silos without business stakeholder input	Policies create friction; business leaders circumvent controls

1.2 Proposed Security Governance Organisational Chart



1.3 RACI Matrix

R = Responsible (Doer), A = Accountable (Owner), C = Consulted, I = Informed

Governance Activity	Director of Info Security	CIO/CTO	CFO	CTO (Elena)	Compliance (Mark)	Board/Audit Committee	Business Unit Leaders
Policy Approval	R	C	C	C	C	A	I
Risk Assessment & Review	R	C	C	C	C	A	C
Incident Response Planning	R	C	C	C	C	A	I
Security Investment Decisions	C	R	A	C	C	I	I
Security Metrics & Board Reporting	R	I	C	I	C	A	I
Compliance Monitoring	C	I	I	I	R	A	C

1.4 Governance Rationale

The proposed governance structure supports effective information security governance through four foundational principles :

- **Accountability:** The Board holds ultimate accountability, with the Director of Information Security Governance as the executive accountable for security programme execution. The RACI matrix clarifies that while the Director is Responsible for activities like policy development and risk assessment, the Board/Audit Committee remains Accountable for approval and oversight.

- **Transparency:** Clear reporting lines from operations through the Security Steering Committee to the Board ensure security posture is visible at all levels. The Director provides regular updates to the SSC and Board-level reporting.
- **Business Alignment:** The SSC includes business unit representatives and the CFO, ensuring security decisions consider business impact. The RACI matrix gives business leaders a Consulted role in risk assessment, ensuring their operational concerns inform decisions.
- **Risk Management:** Formal risk assessment processes, accountability for compliance monitoring, and structured incident response planning replace the reactive, audit-driven approach.

Task 2: Information Security Charter

2.1 GHC Information Security Charter

GLOBALHEALTH CONNECT
INFORMATION SECURITY CHARTER
Version 1.0 - Effective: 20/10/2026

1. Purpose

The Information Security Programme exists to protect GlobalHealth Connect's information assets, including patient data, intellectual property, and operational systems, while enabling business growth, innovation, and regulatory excellence. This Charter establishes the authority, scope, and accountability framework for information security governance across the organisation .

2. Scope

- This Charter applies to:
- All GHC employees, contractors, and temporary staff
- All information assets (data, systems, networks, applications)
- All cloud-based patient management platforms and infrastructure
- All third-party vendors and partners with access to GHC data or systems
- All regions in which GHC operates

3. Authority

The Director of Information Security Governance is delegated authority by the CEO to:

- Develop and enforce information security policies
- Conduct risk assessments and recommend risk treatment
- Escalate security issues to the Security Steering Committee and Board

- Approve security exceptions within defined risk tolerance
- Commission security assessments and audits
- Direct remediation of identified security vulnerabilities

4. Roles and Responsibilities

Role	Key Responsibilities
Board of Directors	Approve risk appetite; hold management accountable for security outcomes
CEO	Oversee security programme; approve major security investments
Director of Information Security Governance	Lead security strategy, policy, and risk management; report to Board
Security Steering Committee	Provide cross-functional oversight; resolve security-business conflicts
All Employees	Comply with security policies; report incidents; complete training

5. Key Principles

- Risk-Based: Security decisions shall be informed by risk assessment and aligned with GHC's risk appetite.
- Business-Aligned: Security shall enable, not impede, GHC's strategic goals of growth, innovation, and operational efficiency.
- Proportionate: Controls shall be appropriate to the value and sensitivity of assets.
- Accountable: Clear ownership shall exist for all security activities .
- Continuously Improving: The security programme shall evolve in response to changing threats and business needs.

6. Reporting Structure

- Operational: Director of Information Security Governance reports to CEO
- Committee: Director presents to Security Steering Committee (quarterly)
- Board: Director presents to Audit & Risk Committee (quarterly); full Board (annually)
- Incident: Material incidents reported to CEO and Board within 24 hours

7. Review and Approval

This Charter shall be reviewed annually by the Security Steering Committee. Changes require approval by the Audit & Risk Committee.

Approved By:

Israel Oluyemi
Chief Executive Officer

Ngozi Okonkwo
Board Member, Audit & Risk Committee

Date: _____

2.2 CFO Justification Memo

TO: Ridwan Bello, Chief Financial Officer
FROM: Director of Information Security Governance
DATE: 5/09/2026

SUBJECT: Information Security Charter - Strategic Justification

The Information Security Charter provides the governance foundation essential to GHC's 2026 strategic goals. Three specific alignments warrant your attention:

Trust and Growth: Our 25% market share expansion target depends on customer confidence in patient data protection. The Charter establishes the accountability and oversight structure that healthcare clients require. Proactive governance reduces breach risk, preserving brand value and client retention.

Operational Efficiency: The 10% overhead reduction target and 99.99% uptime goal are supported by the Charter's risk-based approach. Security incidents cost an average of \$4.45 million per breach, which would consume the entire 10% efficiency gain. The Charter's preventative governance reduces this risk.

Innovation Enablement: AI diagnostics and secure data-exchange require security embedded in development, not bolted on after. The Charter enables this by establishing security governance without blocking innovation.

The Charter provides decision-making clarity, ensuring security investments are proportionate and business-aligned. It also strengthens our Board reporting, enabling informed oversight without excessive compliance burden.

Best Regards
Adebukola O.

Task 3: Board Reporting and Security Metrics

3.1 Board Executive Summary

GLOBALHEALTH CONNECT
SECURITY POSTURE ASSESSMENT
Six-Month Summary (September - February)

Overall Posture Assessment:  **AMBER** (Deteriorating)

The organisation's security posture is trending negatively across multiple indicators over the six-month period. While compliance-related metrics such as training completion show improvement, operational risk indicators (incidents, vulnerabilities, malware) are increasing at an accelerating rate. Immediate attention is required to reverse these trends before a major incident occurs.

Key Indicators Summary

Metric	Current (Feb)	Trend	Status	Business Commentary
High-Risk Incidents	7 (monthly)	↑↑	 RED	Incidents have more than tripled, indicating increasing threat exposure
Phishing Attempts	320/month	↑↑	 RED	113% increase suggests targeted attacks; detection capability improved but exposure rising
Critical Vulnerabilities Patched	22 of 40 (55%)	↓	 RED	Patching is not keeping pace with discovery—exposure increasing

Metric	Current (Feb)	Trend	Status	Business Commentary
Training Completion	70%	↑	● GREEN	Improvement from 45%; awareness programme gaining traction
Malware Detections	50/month	↑	● AMBER	Detections increasing; may reflect both real threats and improved detection

Priority Risks

- 1. Patching Backlog: 45% of critical vulnerabilities remain unpatched. This is our most significant technical risk, increasing likelihood of exploitation.
- 2. Incident Surge: 7 high-risk incidents in February, up from 2 in September, suggests either worsening the threat environment or improved detection. Investigation is required.

Recommendations

- 1. Immediate: Conduct root cause analysis on the 700% incident increase over six months.
- 2. Priority: Increase patching capacity to achieve 85%+ patching within 7 days of critical vulnerability disclosure.
- 3. Strategic: Review whether the security team has adequate resources to maintain defensive posture given the expanding threat landscape.

3.2 Selected Security Metrics

S/N	Metric	Current	Six-Month Trend	Business Commentary
1	Phishing Attempts per Month	320	↑ 113%	Increasing volume indicates GHC is being targeted. This metric helps us understand external threat activity, though the trend suggests either heightened targeting or improved detection.
2	Critical Vulnerabilities Patched (%)	55%	↓ from 67%	This is a leading indicator of breach risk. A 55% patch rate for critical vulnerabilities is concerning and suggests technical debt in vulnerability management.

S/N	Metric	Current	Six-Month Trend	Business Commentary
3	High-Risk Incidents per Month	7	↑ 250% from 2	This is our most important outcome metric. Incidents have more than tripled—business impact in terms of operational disruption and remediation cost is increasing.
4	Security Training Completion (%)	70%	↑ from 45%	One bright spot: our awareness programme is gaining traction. 70% completion suggests the programme is becoming embedded in the culture.
5	Patching Cycle Time	31 days	↔ no change	We are taking, on average, 31 days to patch critical vulnerabilities. In healthcare, where ransomware attacks are common, this is a material risk indicator.

3.3 Metric Selection Rationale

These five metrics were selected for Board oversight because they collectively provide:

- **Forward-Looking Indicators:** Phishing attempts and vulnerability patching predict future breach risk, enabling preventative Board action.
- **Outcome Measures:** High-risk incidents measure real business impact, not just activity. Stakeholders who track cyber metrics report improved decision-making .
- **Operational Reality:** Training completion and patching cycle time reveal whether policies are being followed, reflecting governance effectiveness.
- **Proportionality:** These metrics are appropriate for Board-level reporting because they translate complex security data into business-relevant terms.

Task 4: Security Steering Committee

4.1 Terms of Reference

GLOBAL HEALTH CONNECT
SECURITY STEERING COMMITTEE (SSC)
TERMS OF REFERENCE

1. Purpose

The Security Steering Committee provides cross-functional strategic oversight of GHC's information security programme, ensuring alignment with business objectives, resolving security-related conflicts, and facilitating informed decision-making.

2. Scope

The Committee is authorised to:

- Review and approve security policies and standards
- Oversee security risk management and treatment decisions
- Approve security investment recommendations
- Resolve cross-functional security disputes
- Monitor security performance metrics
- Escalate material risks to the Board

3. Membership

Member	Role	Responsibility
Director of Information Security Governance	Chairman	Set agenda; lead security discussions
Chief Technology Officer (Deborah Alonge)	Member	Represent development & technology perspective
Chief Financial Officer (Ridwan Bello)	Member	Represent financial and enterprise risk perspective
Head of Legal & Compliance (Olamide Johnson)	Member	Represent regulatory and legal considerations

Member	Role	Responsibility
Business Unit Representative	Member	Represent operational business impact
IT Manager (John Taiwo)	Member (advisory)	Provide operational security context

4. Meeting Cadence

- Scheduled: Quarterly (February, May, August, November)
- Emergency: As required for material security incidents

5. Decision Authority

The Committee makes decisions by consensus. In the absence of consensus, the CEO (as the accountable executive) may be consulted. Material decisions (policy approval, significant investments) require Committee approval and are escalated to the Board for information or approval as required.

6. Reporting

- Committee decisions and minutes are documented and reported to the Audit & Risk Committee quarterly.
- The Committee receives security reports, incident summaries, and risk assessments from the Director of Information Security Governance.

7. Review

These Terms of Reference shall be reviewed annually by the Committee and updated as required.

4.2 Sample Meeting Agenda

GLOBALHEALTH CONNECT
SECURITY STEERING COMMITTEE
AGENDA - 7/09/2026

Time: 10:00 AM - 11:30 AM
Location: Boardroom / Virtual

S/N	Item	Lead	Time	Desired Outcome
1	Call to Order & Conflict of Interest	Chair	5 min	Acknowledgement of obligations
2	Approval of Previous Minutes	Chair	5 min	Formal record
3	Key Discussion: Password Policy	CTO / IT Manager	30 min	Resolution of conflict between security friction and business productivity
4	Security Incident Report (February)	Chair	15 min	Awareness of recent incidents and trends
5	Risk Register Review	Chair	15 min	Identification of emerging risks
6	Security Investment Proposal	Chair	15 min	Decision on resource allocation
7	Board Report Approval	Chair	10 min	Finalise March Board reporting
8	AOB & Next Meeting	Chair	5 min	Agree date/time

4.3 CEO Briefing Note

TO: Israel Oluyemi, Chief Executive Officer

FROM: Director of Information Security Governance

DATE: 06/09/2026

SUBJECT: Security Steering Committee -Conflict Resolution and Strategic Alignment

The Security Steering Committee is designed to resolve precisely the type of cross-functional conflict exemplified by the recent password policy dispute between the CTO and IT Manager. By bringing together business, technology, legal, and finance leaders, the Committee ensures that security decisions are evaluated against business impact, not just technical requirements.

The password policy dispute demonstrates why the Committee is necessary: the IT Manager's proposal (16-character passwords changed every 30 days without password manager integration) addresses security but creates unacceptable operational friction. The CTO's balanced alternative (emphasising MFA and secure password management) achieves security goals while preserving productivity.

The Committee will resolve such disputes by:

- Ensuring both security and business perspectives are heard
- Evaluating proposals against risk appetite and business objectives
- Providing clear, authoritative decisions with CEO escalation only for unresolved issues
- Maintaining accountability for implementation

This Committee will maintain strategic alignment by reviewing security decisions against GHC's 2026 goals: growth, efficiency, trust, innovation, and regulatory excellence. The Committee is also responsible for monitoring security metrics and escalating material risks—preventing the near-miss from becoming a breach.

Adebukola O.

Task 5: Governance Maturity Assessment

5.1 Current-State Maturity Assessment

Governance Domain	Current Level	Justification
Policy & Documentation	2 - Initial	Policies exist but are inconsistent, inherited from acquisitions, and not always current. Some documentation exists but is not systematically maintained.
Roles & Responsibilities	2 - Initial	Security ownership and accountability are unclear. No formal RACI exists. Some responsibilities are understood informally but not documented.
Risk Management	1 - Ad Hoc	Reactive approach; no formal proactive assessment process. Risk is addressed when audit findings emerge rather than continuously.
Metrics & Reporting	2 - Initial	Technical metrics exist but are not consistently translated into business impact. Board reporting is informal and non-standardised.
Training & Awareness	2 - Initial	Annual training is mandatory but engagement is low. Training exists but does not change behaviour .
Compliance	2 - Initial	Audit-driven rather than continuously monitored. Compliance preparedness is reactive.

Overall Maturity: Level 2 (Initial)

5.2 Maturity Roadmap (12-18 Months)

Priority Initiative	Objective	Key Activities	Measurable Expected Outcome
1. Governance Foundation	Establish formal security governance structure and mandate	1. Secure Board approval for Information Security Charter 2. Establish Security Steering Committee 3. Define RACI for security activities	Charter approved; SSC meetings commencing by Month 3
2. Policy Standardisation	Consolidate and harmonise policies from acquisitions	1. Inventory all existing policies 2. Develop GHC unified policy framework 3. Implement policy management and approval process	Unified policy set documented and published by Month 9
3. Risk Management Implementation	Build proactive risk assessment capability	1. Define risk appetite with Board 2. Implement risk register 3. Establish quarterly risk assessment cadence	Risk register maintained; risk appetite documented by Month 8
4. Board-Ready Metrics	Transform technical metrics into business-relevant reporting	1. Develop security dashboard 2. Establish reporting cadence 3. Create Board presentation templates	Board receives quarterly security reports from Month 6
5. Training Programme Revitalisation	Increase engagement and behavioural change	1. Conduct training needs assessment 2. Develop role-based training 3. Implement engagement measurement	Training completion >90%; positive engagement survey results by Month 12

Target Maturity: Level 3 (Defined) across all domains within 12-18 months

5.3 Board Executive Summary

TO: GHC Board of Directors

FROM: Director of Information Security Governance

DATE: 10/09/2026

SUBJECT: Security Governance Maturity Assessment and Roadmap

GHC's information security governance is currently assessed at Level 2 (Initial) across most domains; processes exist but are inconsistently documented and applied. This is consistent with the organisation's recent growth trajectory but is no longer acceptable given the near-miss incident and planned expansion.

Achieving Level 3 (Defined) across all domains within 12-18 months will:

- Reduce Breach Risk: Documented, standardised processes supported by clear accountability reduce the likelihood of security gaps that led to the recent near-miss.
- Enable Board Oversight: Defined governance processes provide the visibility and accountability required for Board oversight .
- Support Growth: Mature governance scales with the organisation, enabling continued growth without introducing unsustainable risk.
- Demonstrate Compliance: Formal processes provide evidence for regulatory compliance, reducing audit and enforcement risk.
- Embed Accountability: Clear roles and responsibilities ensure security ownership is understood and enforced at all levels.

The roadmap prioritises governance foundation, policy standardisation, risk management, board metrics, and training; addressing the root causes of current weaknesses while building capability for the future.

References

Info-Tech Research Group. (2014). Information Security Charter Template.

CapEdge. (2025). Graham Holdings Co. DEF 14A Definitive Proxy Statement.

Board Cybersecurity. (2026). Graham Holdings Co. Cyber Governance.

GitHub Governance Infrastructure Layer. Governance Maturity Model.

GHC NHS Trust. (2025). Council of Governors Meeting Minutes.